

Using WAF

(LAB-M10-01)

Overview

In this lab, you will be deploying web server with CDN services to access application from nearest cdn location.

You are securing the application using WAF services to protect it from DDoS attacked.

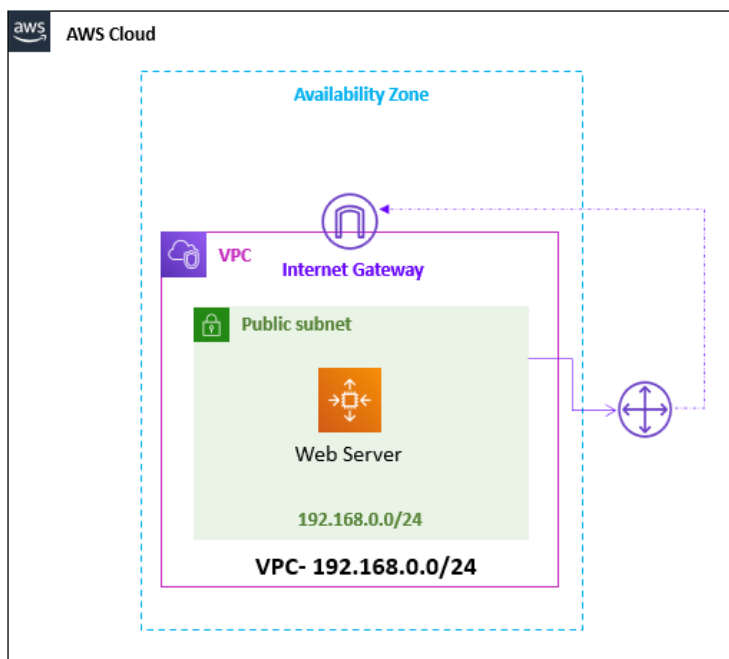
Objectives

After completing this lab, you will be able to:

- Configure CloudFront service.
- Configure WAF service.

Task 1: Deploy Web Server with VPC

In this task of the lab, you will create the VPC and Web Server and Deploy the web app.



Step 1: Deploy Web Server with VPC

AWS CloudFormation model and provision AWS resources in your cloud environment in automated way.

Info: In this task, CloudFormation provision Virtual Network with one Subnet and create Web Server and deploy Web application.

1. In the AWS Management Console, on the **Services** menu, click **CloudFormation**.
2. Choose the **US East (N. Virginia)** region list to the right of your account information on the navigation bar.
3. Click **Create stack**.

- a. In the **Prerequisite - Prepare template** section:
 - i. **Prepare template:** Select **Template is ready**.
- b. In the **Specify template** section:
 - i. **Template source:** Select **Upload a template file**.
 - ii. **Upload a template file:** Click on **choose file** then select the **lab-waf.yaml** file.

Note: **lab-waf.yaml** cloudformation script is available with the lab manual.

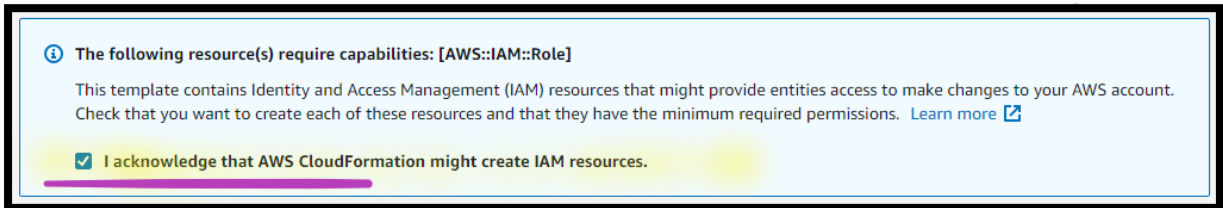
- iii. Click **Next**.
- c. In the **Stack name** section:
 - i. **Stack name:** Write **lab-waf**.

Note: **Change** the **Key pair name**, **if** you have created with different name other than **My-SEC-LAB-KP** under dropdown.

- ii. Click **Next**.
- d. In the **Tags** section:
 - i. **Key:** Write **Name**.
 - ii. **Value:** Write **LAB-WAF**.

Note: Leave other values as default.

- iii. Click **Next**.
- e. In the **Review lab-waf** page:
 - i. **Enable** the **Checkmark** against the ***I acknowledge that AWS CloudFormation might create IAM resources.***

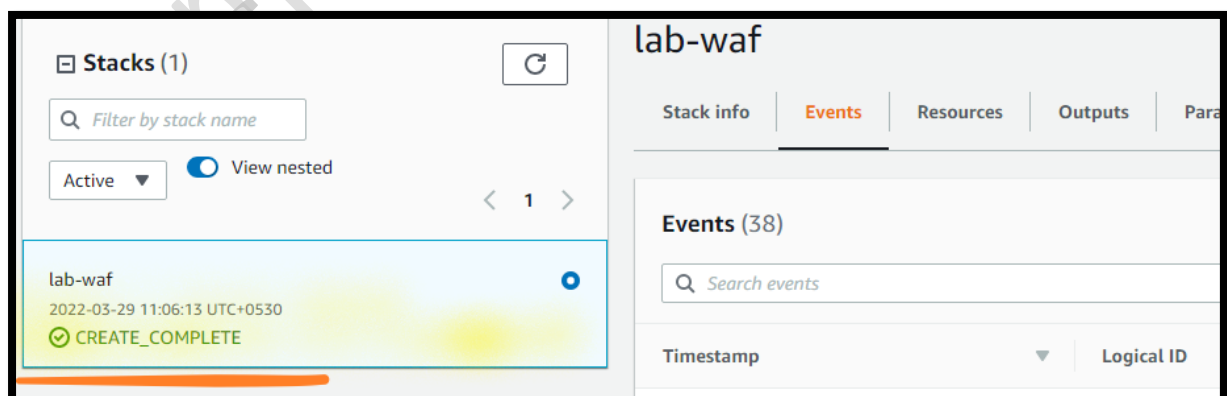


- ii. Click **Create stack**.
- iii. The stack status (**left site under Stack**) is showing as **CREATE_IN_PROGRESS**.

Note: Click on **Refresh** until status is turned into **CREATE_COMPLETE**.

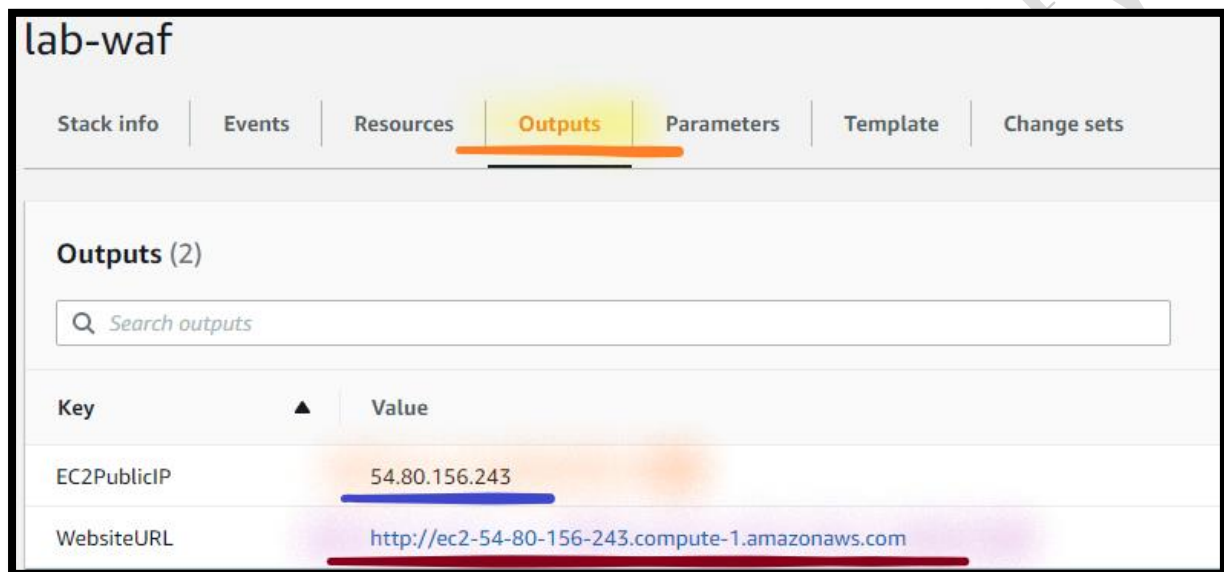
Note: You need to wait till you can see the **CREATE_COMPLETE** status **under Stack** on your **right site**, as shown below.

Note: **Ignore** if you can see any resource **CREATE_IN_PROGRESS** under **Events**.



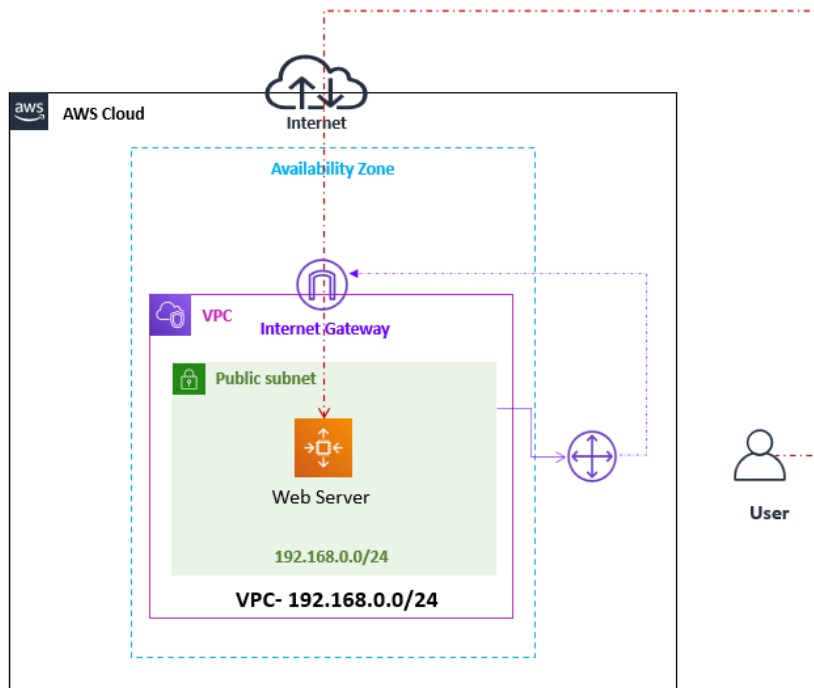
4. From the **lab-waf** Stack:

- a. Go to right, click the **Outputs** tab.
- b. A **CloudFormation stack** can provide **output information**, such as resources details. **You will see outputs**:
 - i. **EC2PublicIP**: The **Static Public IP** address of virtual machine.
 - ii. **WebsiteURL**: The **WebsiteURL** of the web server. **Copy** the **Website URL** in the **Notepad**.

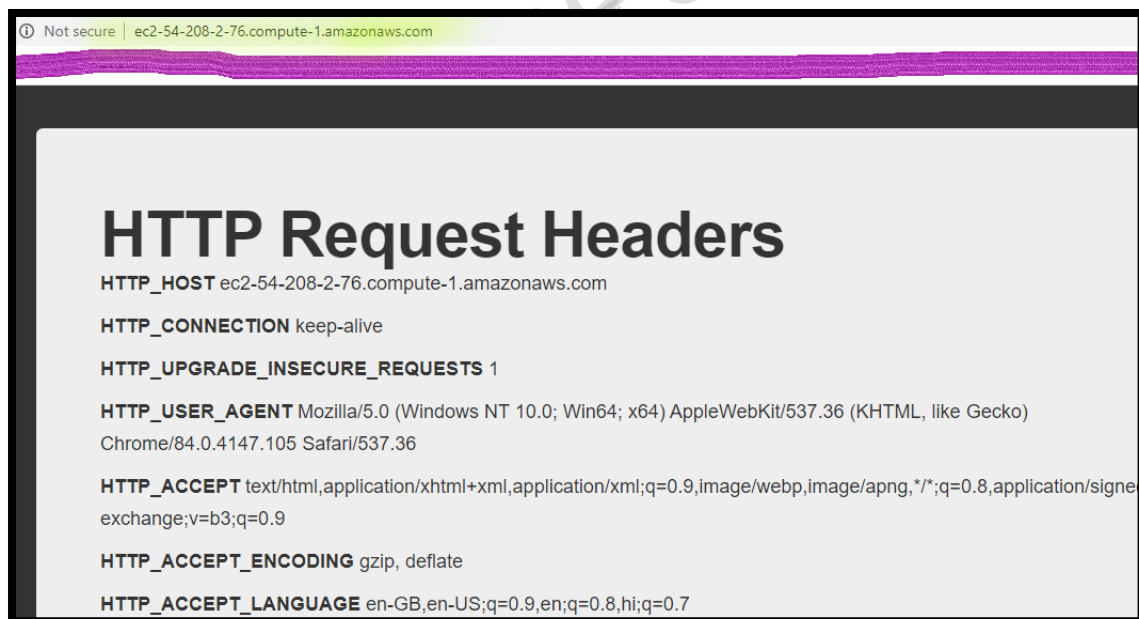


Key	Value
EC2PublicIP	54.80.156.243
WebsiteURL	http://ec2-54-80-156-243.compute-1.amazonaws.com

Step 2: Access the Web Application Server

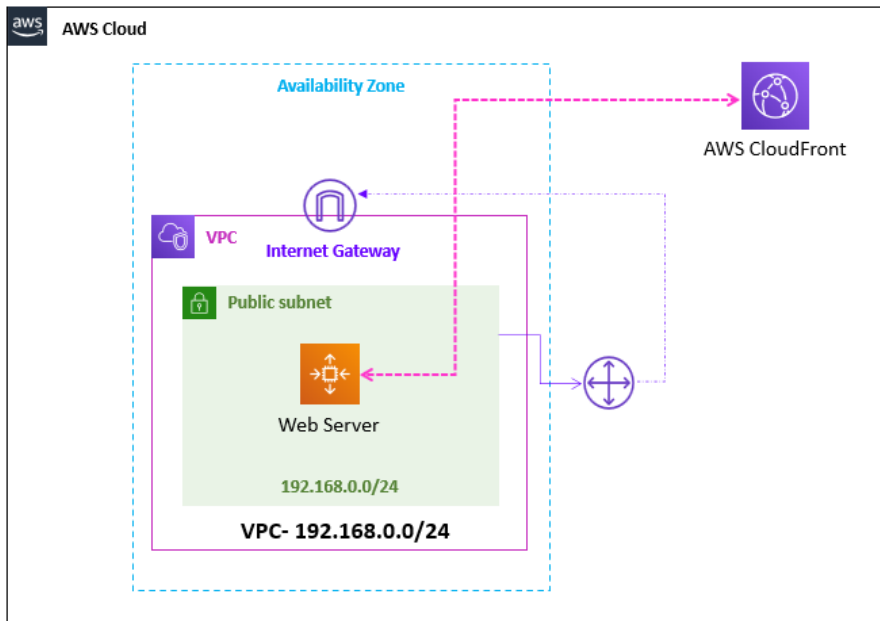


5. From your **Local Desktop/ Laptop Web browser**, type **URL** of **Web Application Server** and access your **Web application**.



Task 2: Create the CDN

In this task of the lab, you will create the CloudFront and integrate with web app.



Step 1: Create a Cloud Front Distribution

6. In the **AWS Management Console**, on the **Services** menu, click **Cloud Front**.
7. Select the **Create a CloudFront Distribution**.
 - a. In the **Origin** section:
 - i. **Origin Domain Name**: **Copy Website-URL** (**without http://**).

Info: An origin is the location where you store the original version of your content. When CloudFront gets a request for your files, it goes to the origin to get the files that it distributes at edge locations.

- ii. **Protocol**: Select the **HTTP Only**.
- iii. **HTTP Port**: Write **80**.

Origin domain
Choose an AWS origin, or enter your origin's domain name.

Protocol [Info](#)

☒ HTTP only

☐ HTTPS only

☐ Match viewer

HTTP port
Enter your origin's HTTP port. The default is port 80.

iv. **Name:** Write **EC2-PHP-Site**.

Origin path - *optional* [Info](#)
Enter a URL path to append to the origin domain name for origin requests.

Name
Enter a name for this origin.

Note: Leave the other details as default.

b. In the **Default cache behavior** section:

i. **Compress objects automatically:** Select **No**.

Path pattern [Info](#)

Compress objects automatically [Info](#)

☒ No

☐ Yes

- ii. **Cache key and origin requests:** Select the **Legacy cache settings**.
 - a) **Headers:** Dropdown and select **All**.
 - b) **Query strings:** Dropdown and select **All**.
 - c) **Cookies:** Dropdown and select **None**.

Note: Leave the other details as default.

- c. In the **Settings** section:
 - i. **Price class:** Select the **Use all edge locations (best performance)**.
 - ii. **Uncheck** the **Checkmark** against the **HTTP/2**.

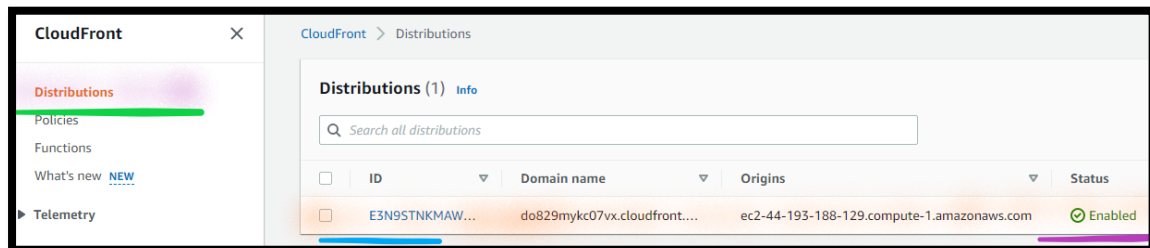
Note: Leave the other details as default.

- d. Select the **Create Distribution**.

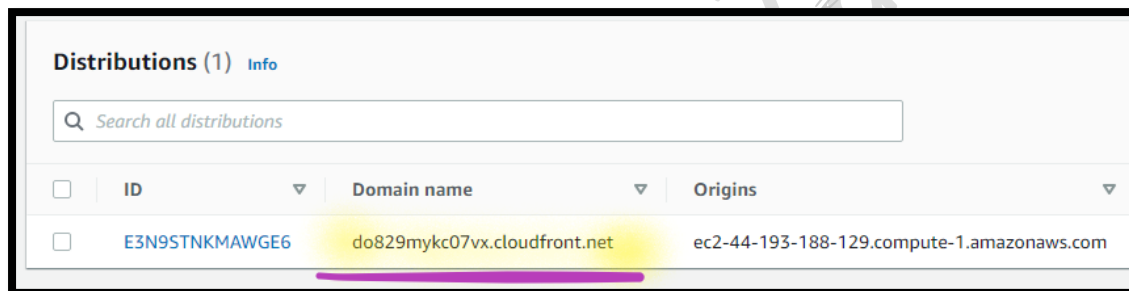
Step 2: Copy the CDN Endpoint

8. From the **CloudFront** page:
 - a. **Go to left** and select the **Distribution**. (if you are not seeing the distribution, click on the **three lines**).

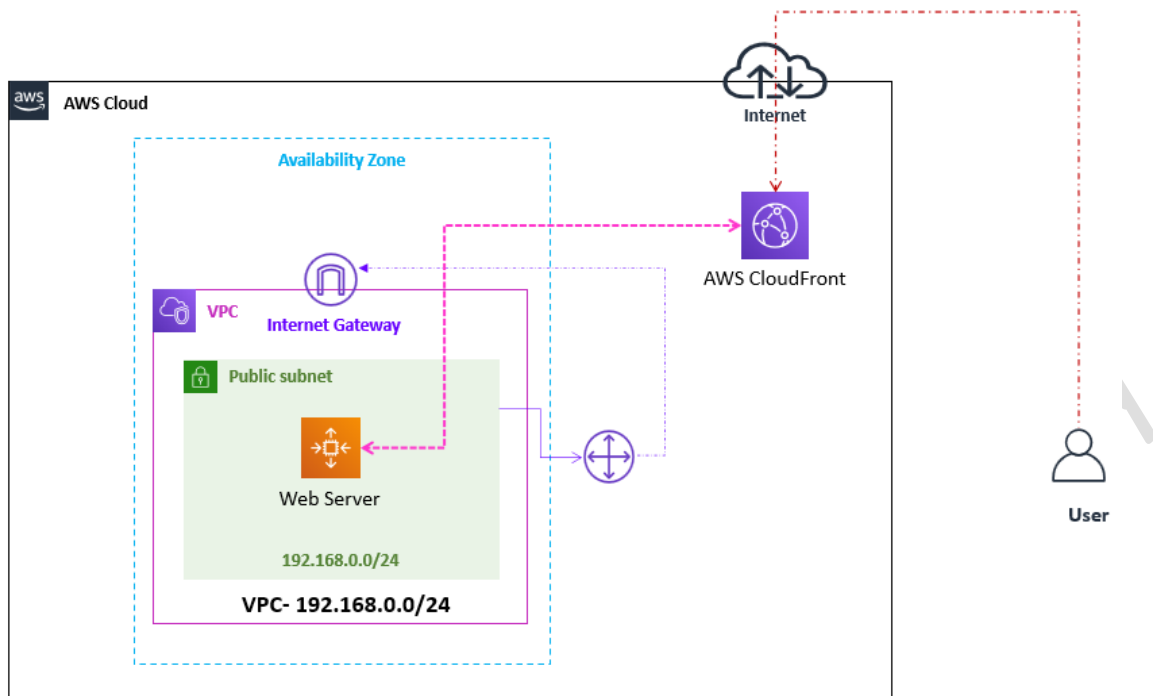
Note: You can see the Distribution **Status** as **Enabled**.



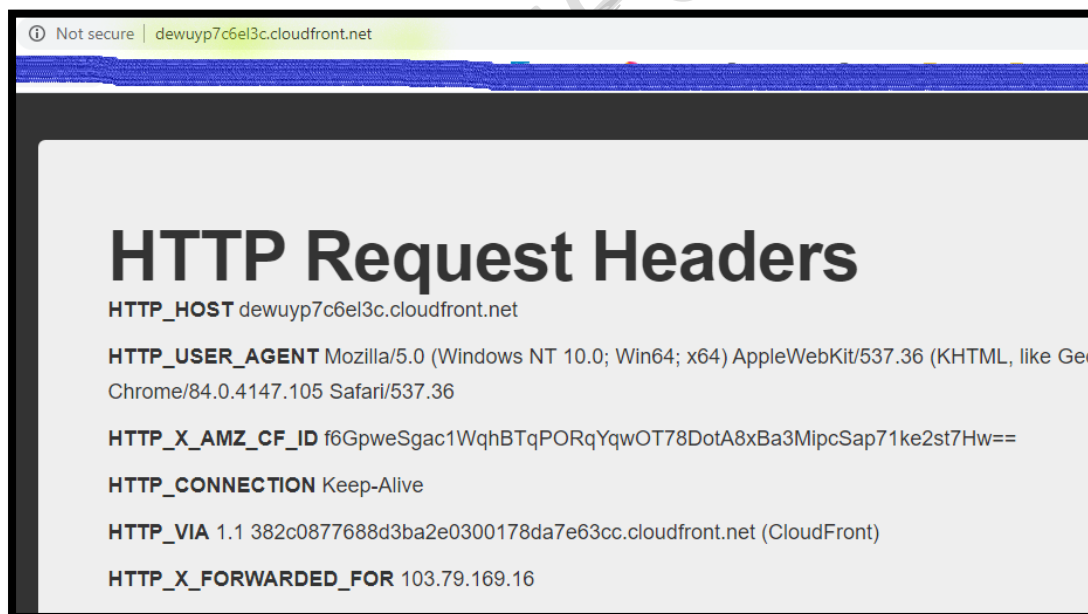
- b. **Copy** the **Domain name** in the **Notepad**.



Step 3: Test your Application using CDN



- From your **local Desktop/ Laptop Web browser**, type **URL** of **CDN Distribution Domain name** and access your **Web application**.



Note: The CloudFront is attaching some additional headers that do not appear in the browser request to WebsiteURL!.

Step 4: Check the CDN Location

Check the AWS EC2 Website location

10. **Copy** the **EC2 Website URL** (without **http://**) .
11. **From** the **local Desktop/ Laptop**, right click on **Start** & **Run**.
 - a. In the **Open**, write **cmd**.
 - b. Press **Ok**.
 - c. In the command prompt write **Ping Website-URL**.

Note: Replace **Website-URL** with your **EC2 instance website URL** (not CDN URL).

```
C:\Users\Ahmad>ping labphpmysql2-env.eba-rhmf7cj.us-east-1.elasticbeanstalk.com

Pinging labphpmysql2-env.eba-rhmf7cj.us-east-1.elasticbeanstalk.com [52.200.91.86] with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 52.200.91.86:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
```

Note: In the response, you get the **Public IP** Address mapped with the EC2 instance website URL.

- d. **Copy** the **Public IP Address** (which you get in the Ping response) in **Notepad**.
12. **Open** the **below URL** from browser of **local Desktop/Laptop**.
<https://db-ip.com>
 - a. **Paste** the **Public IP Address** (which you have copied in the previous step, in the **Lookup IP address** & **press [Enter]** to get the location of the IP Address.



Note: You will get the IP Address region, which **points to the region** where you have **deployed the Website (on EC2)**.

Check the AWS CloudFront response location

13. **Copy** the **CloudFront Domain Name** (without **http://**).
14. **From** the **local Desktop/ Laptop**, right click on **Start** & **Run**.
 - a. In the **Open**, write **cmd**.
 - b. Press **Ok**.
 - c. In the command prompt write **Ping CDN-URL**.

Note: **Replace CDN-URL** with your **CloudFront CDN URL** (not EC2 website URL).

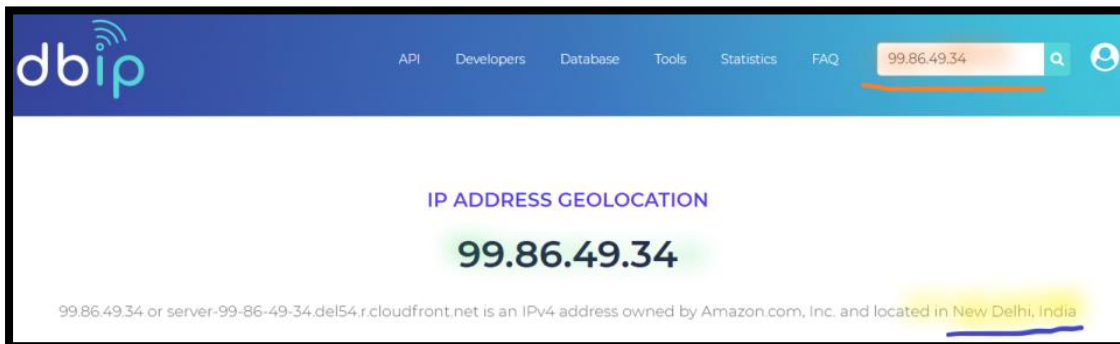
```
C:\Users\Ahmad>ping d1ntdoa7d2eb9t.cloudfront.net

Pinging d1ntdoa7d2eb9t.cloudfront.net [99.86.49.34] with 32 bytes of data:
Reply from 99.86.49.34: bytes=32 time=1ms TTL=246
Reply from 99.86.49.34: bytes=32 time=1ms TTL=246
Reply from 99.86.49.34: bytes=32 time=1ms TTL=246
Reply from 99.86.49.34: bytes=32 time=4ms TTL=246

Ping statistics for 99.86.49.34:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 1ms, Maximum = 4ms, Average = 1ms
```

- d. **Copy** the **Public IP Address** (which you get in the **Ping response**) in **Notepad**.
15. **Open** the **below URL** from browser of **your local desktop/ILaptop**.
<https://db-ip.com>

- a. **Paste** the **Public IP Address** (which you have copied in the previous step, in the **Lookup IP address** & **press [Enter]** to get the location of the IP Address.

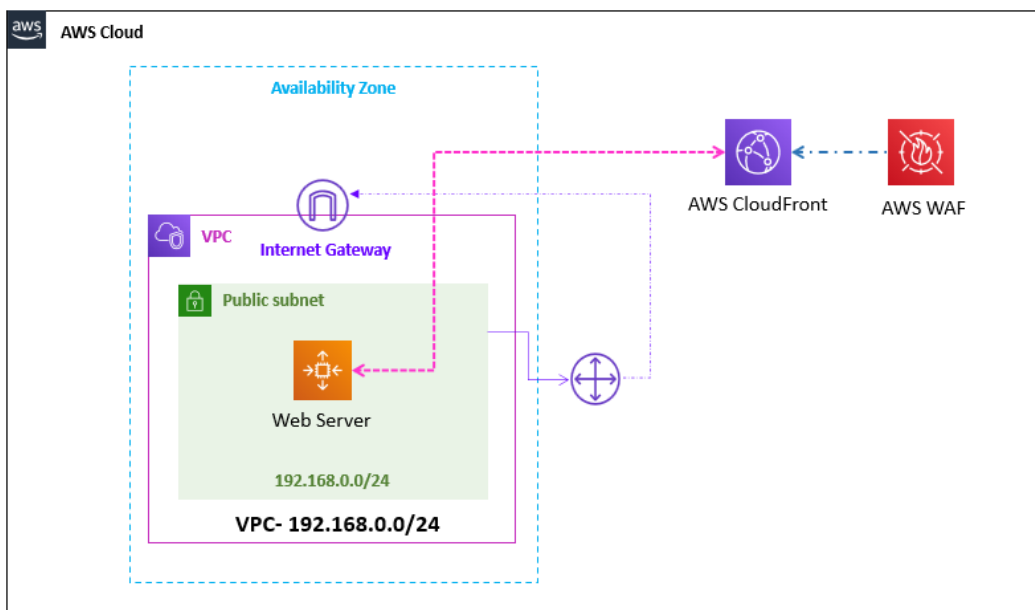


Note: You will get the IP Address region, which **points to the nearest CDN region**.

Note: This shows that using the same URL you can access application from nearest CDN region across the globe.

Task 3: Deploy the WAF Web ACL

In this task, you will create the AWS WAF Web ACL with conditions and resources.

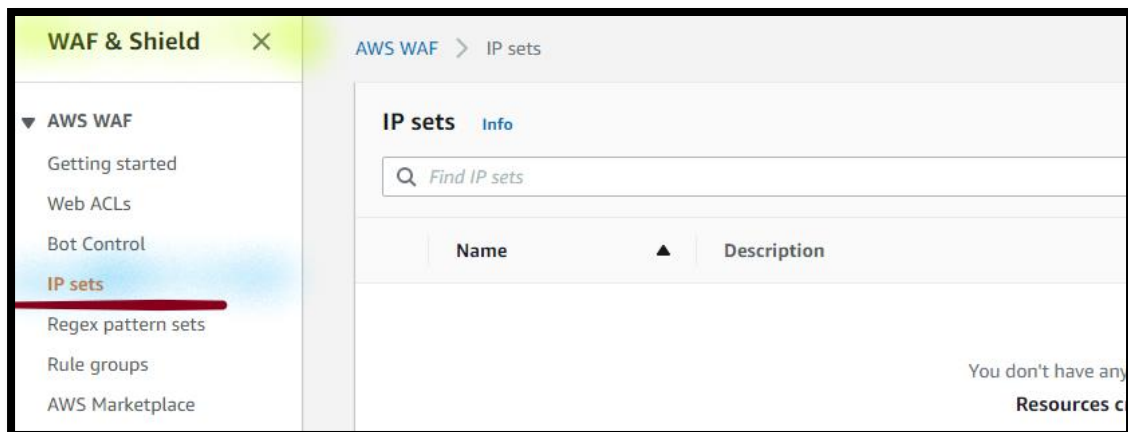


Step 1: Create an IP Set

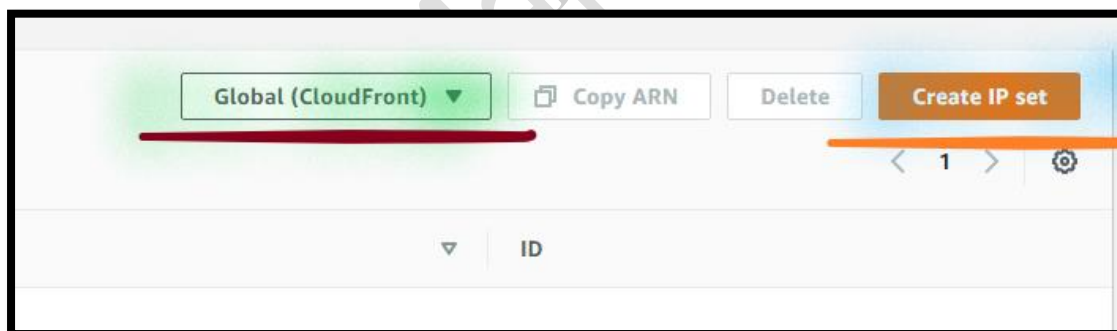
An IP set provides a collection of IP addresses and IP address ranges that you want to use together in a rule statement.

16. In the **AWS Management Console**, on the **Services** menu, Click **WAF & Shield**.

17. **Go to left**, select the **IP sets**.



- Choose the **Global (CloudFront)** region from **Dropdown menu** from the IP sets.
- Select the **Create IP set**.



- In the **IP set details** section:
 - IP set name:** Write **LabIPMatch**.
 - Region:** Dropdown and select the **Global(CloudFront)**.
 - IP version:** Select the **IPv4**.

IP set name

LabIPMatch

The name must have 1-128 characters. Valid characters: A-Z, a-z, 0-9, - (hyphen), and _ (underscore).

Description - optional

The description can have 1-256 characters.

Region

Choose the AWS region to create this IP set in.

Global (CloudFront)

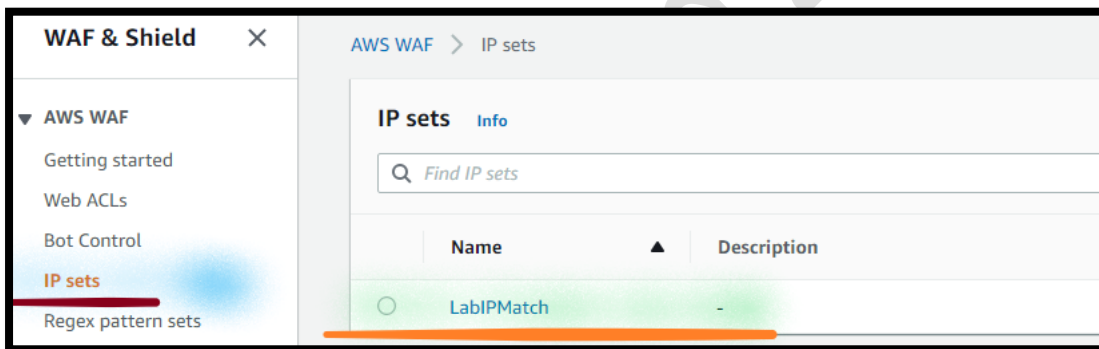
IP version

☒ IPv4

☐ IPv6

d) Select the **Create IP set**.

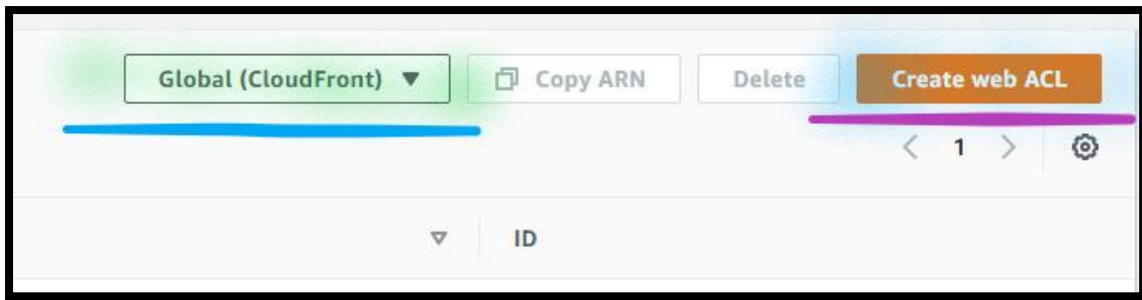
Note: You will see the **LabIPMatch** in the IP Set.



Step 2: Create a Web ACL

18. From the **WAF & Shield** page:

- Go to left and Select the **Web ACLs**.
- Choose the **Global (CloudFront)** region from **Dropdown menu** from the IP sets.
- Select the **Create web ACL**.

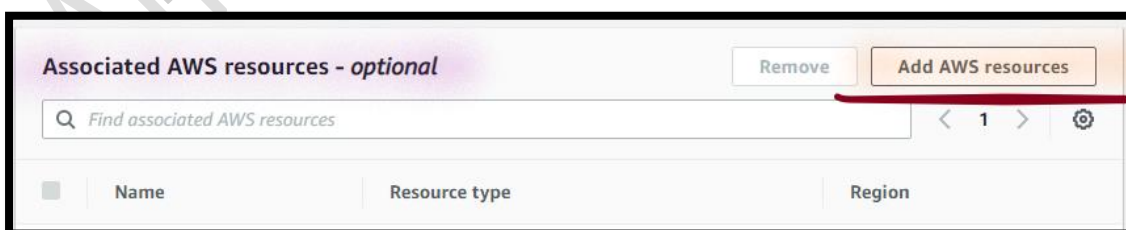


i. In the **Web ACL details** section:

- 1) **Web ACL name:** Write **Lab-ACL**.
- 2) **Resource type:** Select the **CloudFront distributions**.

ii. In the **Associated AWS resources** section:

- 1) Select the **Add AWS resources**.



2) From the **Add AWS resources** page:

- a) Select the **CloudFront distribution** (which you have created in the previous step and which is the only entry in the list).

Add AWS resources

Resource type
Select the resource you want to associate with this web ACL.

☒ CloudFront Distribution

Select the resources you want to associate with the web ACL.

Find AWS resources to associate

☒	Name
☒	E3N9STNKMAWGE6 - do829mykc07vx.cloudfront.net

b) Select the **Add**.

Note: You will see the **CloudFront distribution** under **Associated AWS resources** section.

Associated AWS resources - optional

Remove Add AWS resources

Find associated AWS resources

☐	Name	Resource type	Region
☐	E3N9STNKMAWGE6 - do829mykc07vx.cloudfront.net	CloudFront Distribution	Global (CloudFront)

c) Select the **Next**.

iii. In the **Add rules and rule groups** page:

1) In the **Rules** section:

a) Select the **Add rules**.

b) Dropdown and select the **Add my own rules and rule groups**.

Rules

If a request matches a rule, take the corresponding action. The rules are prioritized in order they appear.

Edit Delete Add rules ▲

Add managed rule groups

Add my own rules and rule groups

No rules.

c) In the **Add my own rules and rule groups** section:

d) In the **Rule type** section:

I. Select the **Rule builder**.

e) In the **Rule** section:

I. **Name:** Write **LabRule**.

II. **Type:** Select the **Regular rule**.

f) **If a request:** Dropdown and select the **matches the statement**.

g) In the **Statement** section:

I. **Inspect:** Dropdown and select **Originates from an IP address in**.

II. **IP set:** Dropdown and select the **LabIPMatch**.

III. **IP address to use as the origination address:** Select the **Source IP address**.

Statement

Inspect

Originates from an IP address in ▼

IP set

LabIPMatch ▼

IP address to use as the originating address

When a request comes through a CDN or other proxy network, the source IP address identifies the proxy and the original IP address is sent in a header. Use caution with the option, IP address in header, because headers can be handled inconsistently by proxies and they can be modified to bypass inspection.

☒ Source IP address

☐ IP address in header

h) In the **Action** section:

I. **Action:** Select the **Block**.

Action

Action

Choose an action to take when a request matches the statements above.

☐ Allow

☒ Block

☐ Count

☐ CAPTCHA

► Custom response - *optional*

► Add label - *optional*

Add labels to requests that match this rule. Rules that are evaluated later in the same web ACL can reference the labels that this rule adds.

i) Select the **Add rule**.

Note: You will see the **LabRule** in the Rules.

Rules

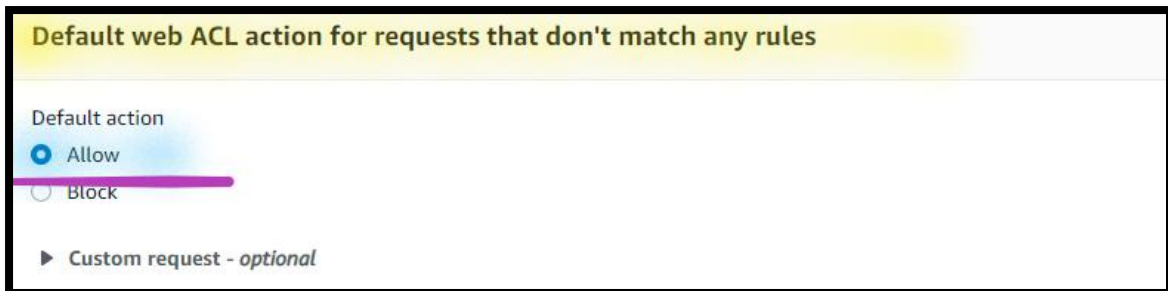
If a request matches a rule, take the corresponding action. The rules are prioritized in order they appear.

Edit Delete Add rules ▼

☐	Name	Capacity	Action
☐	LabRule	1	Block

j) In the **Default web ACL action for requests that don't match any rules** section:

I. **Default action:** Select the **Allow**.



Default web ACL action for requests that don't match any rules

Default action

☒ Allow

☐ Block

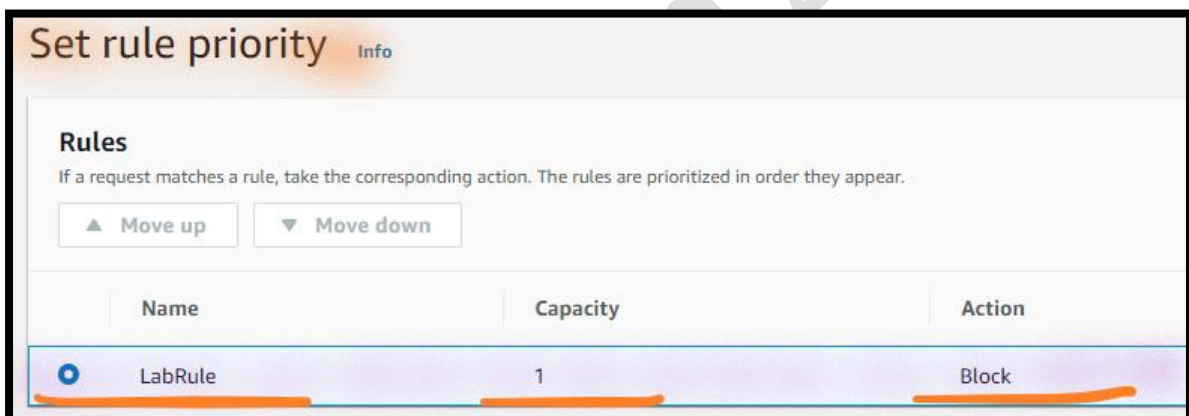
► Custom request - optional

II. Select the **Next**.

k) In the **Set rule priority** section:

I. **Rules:** Select the **LabRule**.

II. Select the **Next**.



Set rule priority Info

Rules

If a request matches a rule, take the corresponding action. The rules are prioritized in order they appear.

▲ Move up ▼ Move down

Name	Capacity	Action
☒ LabRule	1	Block

l) In the **Configure metrics** section:

Note: Leave the values as default.

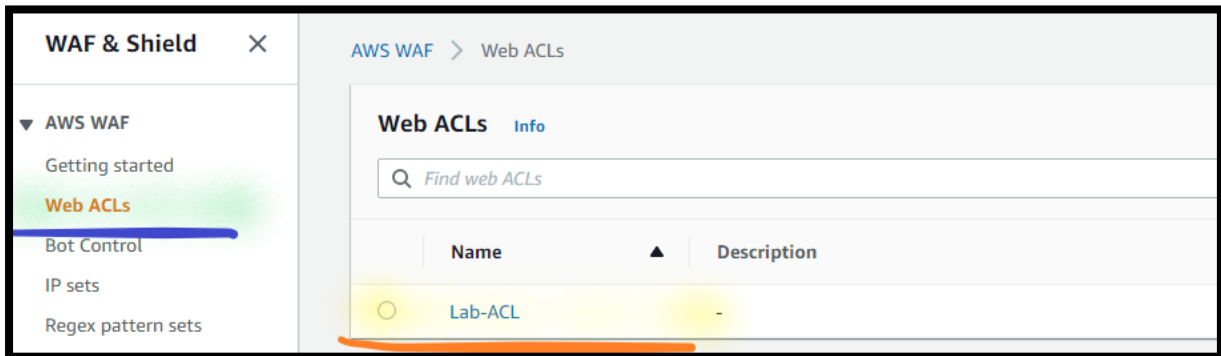
I. Select the **Next**.

iv. In the **Review and create web ACL** section:

Note: Leave the values as default.

1) Select the **Create web ACL**.

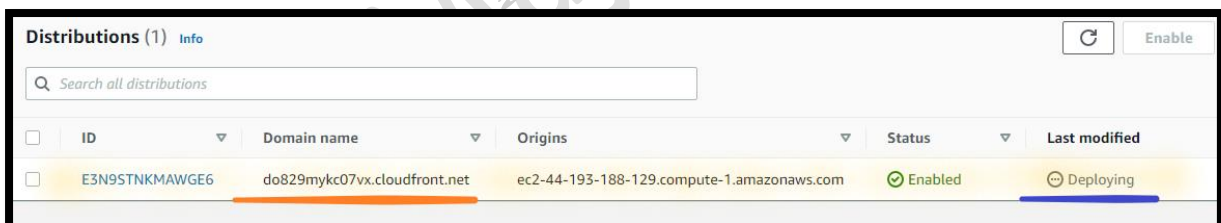
Note: You will see the **Lab-ACL** under Web ACLs.



Step 3: View CDN status

19. In the **AWS Management Console**, on the **Services** menu, click **CloudFront**.
 - a. **Go to the left**, select **Distributions**.
 - b. Select your **CloudFront Distribution**.

Note: The distribution **Status** is displayed **Enabled** and the **Last modified** status appears **Deploying**.



Note: The Web ACL becomes active when the deployment has completed. There is **no need to wait** for the distribution to be complete. Please **continue with the next steps**.

Task 4: Block Website Access from EC2 Virtual machine

In this task you will blocked the access to your web server directly and allow the web application can only be accesed from CDN services.

Step 1: Copy the Web Server Public IP address

20. In the **AWS Management Console**, on the **Services** menu, click **EC2**.

21. Click the **Instances**.

22. Select the **Web Server**.

- a. **Go below** in the console and select the **Details**.
- b. **Expand** the **Instance summary**.
 - i. **Copy** the **Public IP address** in the **Notepad**.

Step 2: Connect to the Web Server using SSH

23. **Connect** to the **Web Server** using the **PuTTY**.

Note: Use the **My-SA-LAB-KP.ppk** to connect to the Server.

- a. **Login as:** Type **ec2-user**.

Note: You can see the Linux console.

Step 3: Run Security Group Updates

In this task, you will run a security group update script. The web server ports on your EC2 instance are accessible to the world. As a security best practice, you can modify the security group rules to only allow only requests coming from CloudFront.

The range of IP addresses that belong to CloudFront are retrieved from the AWS IP Address Ranges (<https://ip-ranges.amazonaws.com/ip-ranges.json>).

There is a script (**cloudfront_sgs.py**) on your instance to update the webserver security groups.

24. From the **Web Server**:

- Execute** the **below command** from **Linux terminal**.

```
python3 cloudfront_sgs.py
```

Note: The script has automated the process of retrieving the CloudFront IP ranges from the AWS IP Address Ranges and uses these to update the WebServer security group.

Note: Go to the next step, but **Don't close the Linux terminal**.

Step 4: Review WebApp Server Security Group

25. In the **AWS Management Console**, on the **Services** menu, click **EC2**.

26. Click **Instances**.

27. Select the **Web Server**.

- Go below** in the console and click on the **Security**.
- Expand the inbound rules**.

Note: The inbound rules been populated with the **IP ranges that belong to CloudFront**.

Instance: i-0916718eef1e6b9a4 (Lab-WAF-Web-Server)

▼ Inbound rules

Q Filter rules

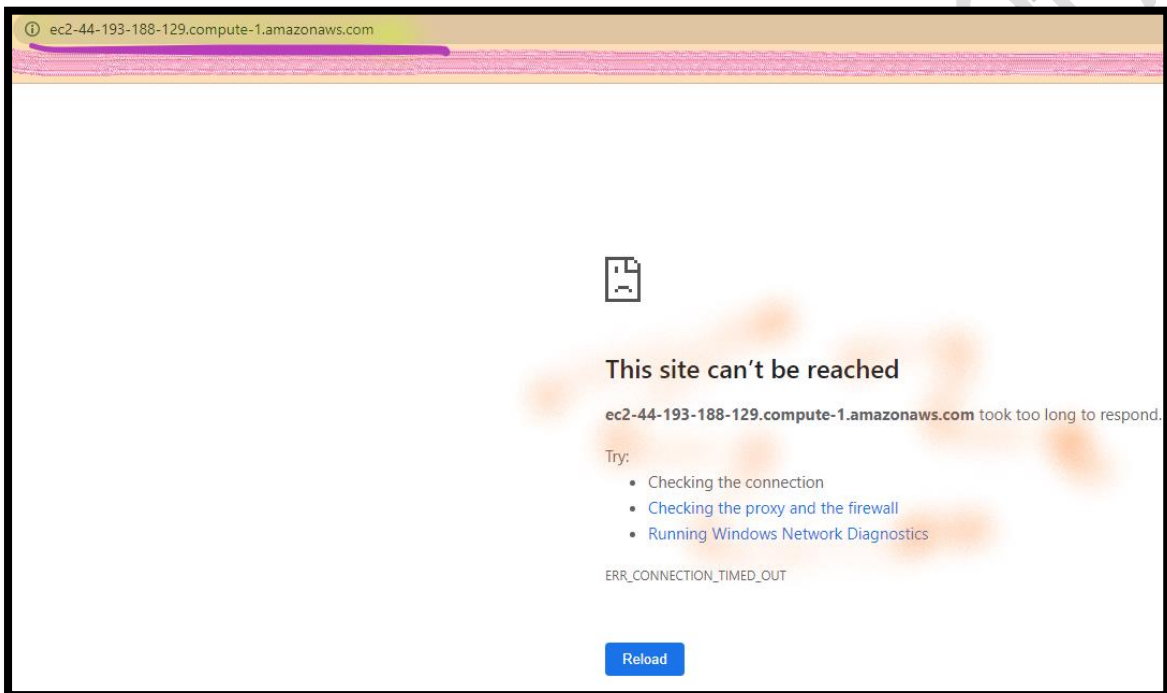
Security group rule ID	Port range	Protocol	Source	Security groups	CLOUDFRONT-d
sgr-044f9892cc8915a10	80	TCP	54.233.255.128/26	CLOUDFRONT-only-3	⊙
sgr-05ccddc9c4393a67f	80	TCP	3.236.48.0/23	CLOUDFRONT-only-3	⊙
sgr-05dec9b0583f8c1e3	80	TCP	34.195.252.0/24	CLOUDFRONT-only-3	⊙
sgr-0b697fc0b60b164f8	80	TCP	3.101.158.0/23	CLOUDFRONT-only-3	⊙
sgr-0131e004d52562f3f	80	TCP	52.212.248.0/26	CLOUDFRONT-only-3	⊙
sgr-0f7fa2451b3a17d77	80	TCP	44.234.90.252/30	CLOUDFRONT-only-3	⊙
sgr-0dba877d1f637c457	80	TCP	35.162.63.192/26	CLOUDFRONT-only-3	⊙
sgr-0191212b6cc50131f	80	TCP	3.11.53.0/24	CLOUDFRONT-only-3	⊙
sgr-0d66bdd6970b089ad	80	TCP	34.223.12.224/27	CLOUDFRONT-only-3	⊙
sgr-00b0014a2923fa84c	80	TCP	13.48.32.0/24	CLOUDFRONT-only-3	⊙

Step 5: Access WebApp Server

28. From your **Local Desktop/ Laptop Web browser**, type **URL** of **Web Application Server** and access your **Web application**.

Note: WebsiteURL **will not respond**. The script has **restricted access** to only **allow** requests originating from **CloudFront**.

Note: **Close** the **website** you are accessing using the **Web Application DNS Server**.

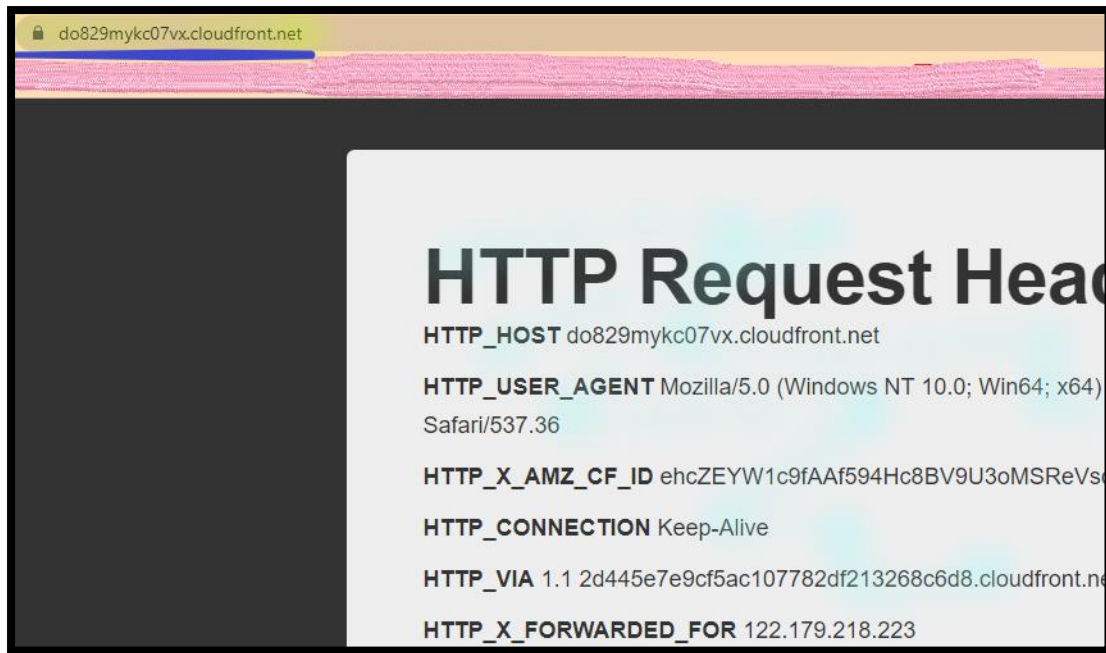


Step 6: Access WebApp Server using CDN

29. From your **Local Desktop/ Laptop Web browser**, type **URL** of **CDN Distribution Domain name** and access your **Web application**.

Note: You can access your website, as **website can only be accessible from CDN**.

Note: Go to the next step, but **Don't close the Web server**.



Task 5: Run WAF Updates for X-Forwarded-For

Info: The **X-Forwarded-For** request header helps you identify the IP address of a client, if the viewer did use an HTTP proxy to send the request.

With this feature, you can reference these headers to write rules, allowing you to take action on IPs that are found within these headers.

Step 1: View the Web server configuration

30. **Return** to the **Web Server**:

a. **Execute** the **below command** from **Linux terminal**.

```
sudo cat /etc/httpd/conf/httpd.conf
```

Note: The very last line LogFormat configures the webserver to log the **X-Forwarded-For** header. This is the IP address that made the original request which Cloudfront forwarded on to your web server instance.

Step 2: View the Contents of your web server logs

- a. **Execute** the below command from **Linux terminal**.

```
sudo cat /var/log/httpd/access_log
```

Note: This log contains the entries created when you accessed the CloudFront URL at the beginning of the lab. The IP addresses in **parenthesis** is the X-Forwarded-For header passed to the web application by CloudFront.

Step 3: View the X-Forwarded-For IP addresses

- a. **Execute** the below command from **Linux terminal**.

```
sudo python3 waf_ip_update.py
```

Note: The script provided will find the **top 10 X-Forwarded-For IP addresses** in the web server logs, and use this to update the **Lab-IP-Match** (of AWS WAF) created earlier.

Note: If you see an error at this step, ensure your Web ACL has been configured correctly.

```
[ec2-user@ip-10-1-0-98 ~]$ sudo python waf_ip_update.py

Top 10 IP Addresses
=====
IP                Count
-----
103.79.169.16     84
103.79.169.3      52
103.79.169.17     27
103.79.169.15     26
103.79.169.29     5

Updating IP set:  Lab-IP-Match
Done!
```

Step 4: Access WebApp Server using CDN

31. **Return** to the **Web browser** and **Refresh**.

Note: **Refresh** the **CloudFront URL** tab **every 30 seconds** until you see the **request blocked message**.

You should see that your IP address has been **blocked by AWS WAF**.



Note: Go to the next step, but **Don't close the Web browser**.

Step 5: View the CDN from Non-Proxy Servers

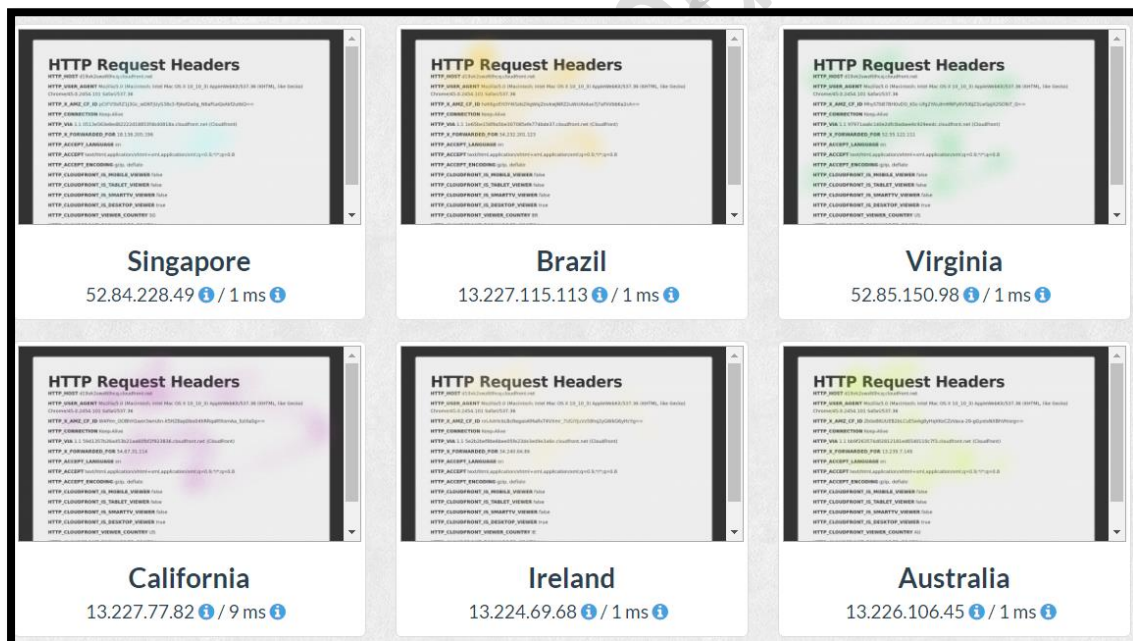
32. **Open** the **below URL** from your **local Desktop/Laptop**.

<https://geopeeker.com/>

33. **Copy** the **CDN Domain Name** & Select **Go**.



Note: Here you can **see the website response from various locations** & display page.



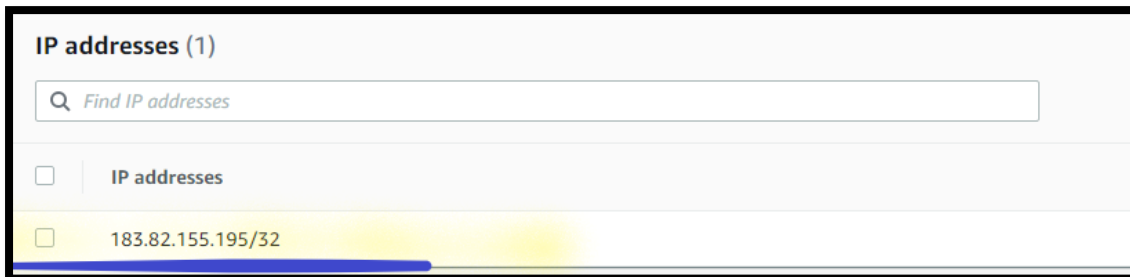
Step 6: View the Blocked IP addresses

34. In the **AWS Management Console**, on the **Services** menu, Click **WAF & Shield**.

a. **Go to the left**, select the **IP sets**.

- b. Choose the **Global (CloudFront)** region from **Dropdown menu** from the IP sets.
- c. Open the **LABIPMatch**.

Note: The Lab IP Match set has been updated with the IP addresses sent from the web server EC2 instance.



- d. Select **IP addresses or range**.
- e. Select **Delete**.
 - i. When prompt to confirm deletion, type **delete**.
- f. Select **Delete**.

Step 7: Access WebApp Server using CDN

- 35. **Return** to the **Web browser** and **Refresh**.

Note: Confirm you are **no longer blocked** on the **CloudFront URL**.

Note: Go to the next step, but **Don't close the Web browser**.

Task 5: Add WAF Rules for Cross-Site Scripting (XSS)

In this task, you will create a cross-site scripting condition and rule. The rule is added to the Lab Web ACL.

Info: Cross-Site Scripting (XSS) attacks are those where the attacker uses vulnerabilities in a benign website as a vehicle to inject malicious client-site scripts (like Javascript) into other legitimate user's web browsers. This XSS match condition feature prevents these vulnerabilities in your web application by inspecting different elements of the incoming request.

Step 1: Create WAF Condition

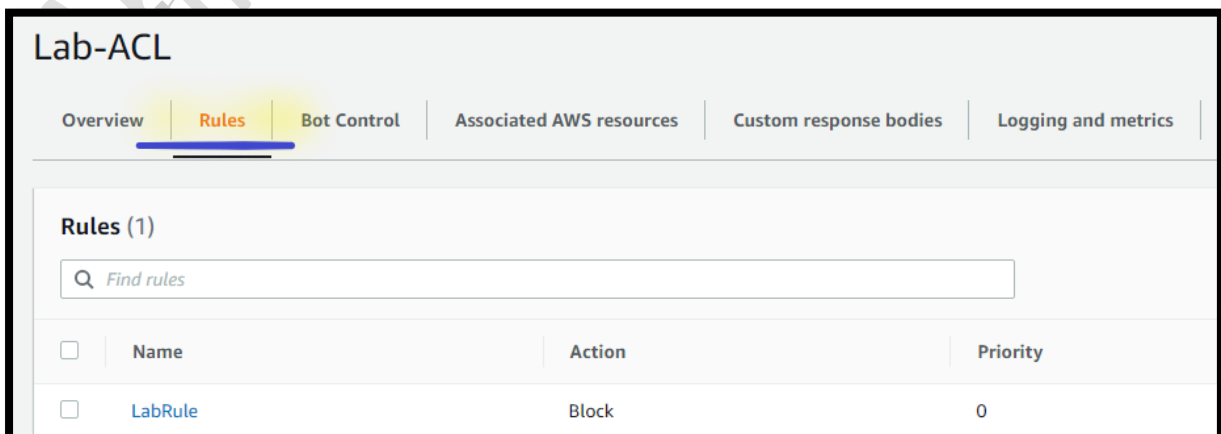
36. In the **AWS Management Console**, on the **Services** menu, Click **WAF & Shield**.

37. **Go to left** and Select the **Web ACLs**.

- Choose the **Global (CloudFront)** region from **Dropdown menu** from the **Web ACLs**.
- Open** the **Lab-ACL**.



- Select **Rule**.



- d. Select **Add rules**.
- e. Select **Add my own rules and rule groups**.



- i. In the **Rule type** section:
 - a) Select **Rule builder**.
- ii. In the **Rule** section:
 - a) **Name**: Write **LABXSS**.
 - b) **Type**: Select **Regular rule**.

A screenshot of a web form for configuring a rule. The 'Name' field contains 'LABXSS'. Below it, a message states: 'The name must have 1-128 characters. Valid characters: A-Z, a-z, 0-9, - (hyphen), and _ (underscore)'. The 'Type' section has two radio buttons: 'Regular rule' (selected) and 'Rate-based rule'.

- iii. **If a request**: Dropdown and select **matches the statement**.

A screenshot of a web form showing a dropdown menu. The dropdown is open, displaying the text 'matches the statement'.

- iv. In the **Statement** section:
 - a) **Inspect**: Dropdown and select **Query string**.
 - b) **Match type**: Dropdown and select **Contains XSS injection attacks**.
 - c) **Transformation**: Dropdown and select **URL decode**.

Inspect

Query string ▼

Match type

Contains XSS injection attacks ▼

Text transformation

AWS WAF applies all transformations to the request before evaluating it. If multiple text transformations are added, then text transformations are applied in the order presented below with the top of the list being applied first.

URL decode ▼

v. In the **Action** section:

a) **Action**: Select **Block**.

Action

Choose an action to take when a request matches the statements above.

☐ Allow

☒ Block

☐ Count

☐ CAPTCHA

vi. Select the **Add rule**.

Note: You can see the LABXSS rule.

Rules

If a request matches a rule, take the corresponding action. The rules are prioritized in order they appear.

▲ Move up ▼ Move down

	Name	Capacity	Action
☐	LabRule	1	Block
☒	LABXSS	50	Block

vii. Select the **Save**.

Step 2: Access WebApp Server using CDN

38. **Return** to the **Web browser**.

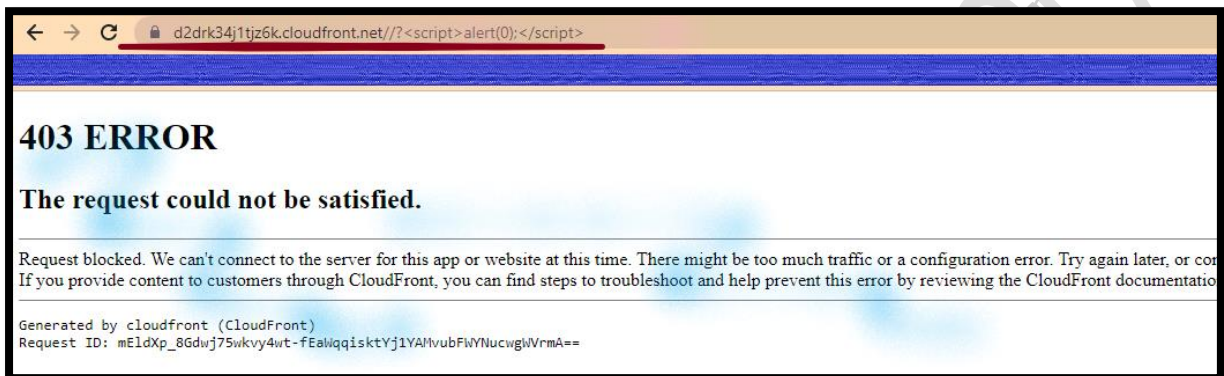
a. **Update** the **CDN URL** and **append** with a **query** (script) **string**.

© No part of this manual, may be reproduced in whole or in part in any manner without the permission of the copyright owner.

[https://ClodFront-Domain-Name/?<script>alert\(0\);</script>](https://ClodFront-Domain-Name/?<script>alert(0);</script>)

Note: Replace the **CloudFront-Domain-Name** with **your CDN Domain name**.

Note: When you attempt to visit the URL with the script, AWS WAF will block the XSS style request.



Note: Go to the next step, but **Don't close the Web browser**.

Task 6: Add WAF Rules for SQL Injection

In this task, you attempt to add a SQL injection match condition to the Lab ACL.

Info: SQL injection is a web security vulnerability that allows an attacker to interfere with the malicious SQL statements that an application makes to its database.

Step 1: Create WAF Condition

39. In the **AWS Management Console**, on the **Services** menu, Click **WAF & Shield**.

40. **Go to left** and Select the **Web ACLs**.

- a. Choose the **Global (CloudFront)** region from **Dropdown menu** from the **Web ACLs**.
- b. **Open** the **Lab-ACL**.
- c. Select **Rule**.
- d. Select **Add rules**.
- e. Select **Add my own rules and rule groups**.
 - i. In the **Rule type** section:
 - a) Select **Rule builder**.
 - ii. In the **Rule** section:
 - a) **Name**: Write **LABSQL**.
 - b) **Type**: Select **Regular rule**.
 - iii. **If a request**: Dropdown and select **matches the statement**.
 - iv. In the **Statement** section:
 - a) **Inspect**: Dropdown and select **Query string**.
 - b) **Match type**: Dropdown and select **Contains SQL injection attacks**.
 - c) **Transformation**: Dropdown and select **URL decode**.
 - v. In the **Action** section:
 - a) **Action**: Select **Block**.
 - vi. Select the **Add rule**.

Note: You can see the LABSQL rule.

- vii. Select the **Save**.

Step 2: Access WebApp Server using CDN

41. **Return** to the **Web browser**.
 - a. **Update** the **CDN URL** and **append** with a **query** (script) **string**.

<https://CloudFront-Domain-Name/?Select+1+From+BobbyTables>

Note: Replace the **CloudFront-Domain-Name** with **your CDN Domain name**.

Note: When you attempt to visit the URL with the included script block AWS WAF will block the SQL Injection style request.

Task 7: Access the CDN with the Domain Name

Step 1: Generate Certificate

42. In the **AWS Management Console**, on the **Services** menu, click **Certificate Manager**.

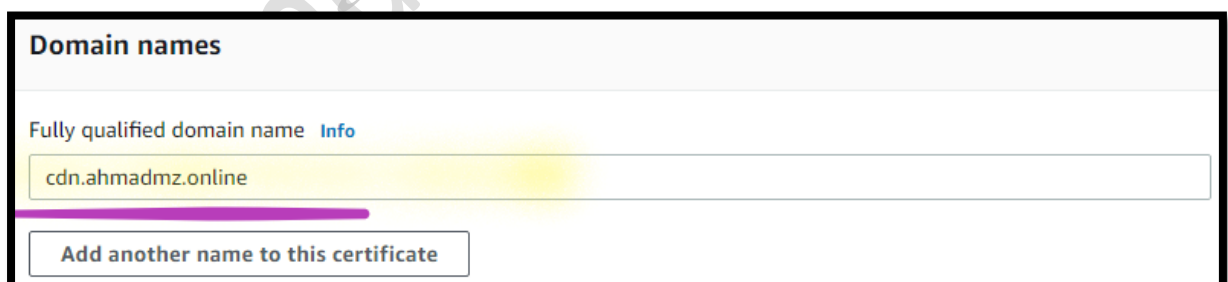
43. Select **Request a certificate**.

a. In the **Certificate type** section:

- i. Select **Request a public certificate**.
- ii. Select **Next**.

b. In the **Domain names** section:

- i. **Fully qualified domain name:** Write **cdn.YOUR_DOMAIN** (like **cdn.ahmad.com**).



Domain names

Fully qualified domain name [Info](#)

cdn.ahmadmz.online

Add another name to this certificate

ii. **Select validation method:** Select **DNS validation - recommended**.

c. Select **Request**.

Note: You can see the **Certificate** with **Pending validation**.

Note: If you can not see the Certificate, **Refresh** your screen.

☐	Certificate ID	Domain name	Type	Status	In use?
☐	5fc3cf57-ed7c-4a41-a16f-2e28ef023551	cdn.ahmadmz.online	Amazon Issued	Pending validation	No

Step 2: Validate the Certificate

44. From the **Certificate console**:

- a. Open the **Certificate ID**.
 - i. Select **Create records in Route 53**.
 - ii. Select **Create records**.

Note: You can see the message **Successfully created DNS records**.

Step 3: Verify the DNS Records

45. In the **AWS Management Console**, on the **Services** menu, click **Route53**.

46. **Go to the left**, select **Hosted zones**.

- a. Open your **Domain name**.

Note: You can see the **new record** created for **ACM validation**.

Records (5) Info					Delete record	Import zone file	Create
Automatic mode is the current search behavior optimized for best filter results. To change modes go to settings.							
Filter records by property or value				Type	Routing policy	Alias	< 1
☐	Record name	Type	Value/Route traffic to				
☐	ahmadmz.online	NS	ns-132.awsdns-16.com. ns-1756.awsdns-27.co.uk. ns-593.awsdns-10.net. ns-1078.awsdns-06.org.				
☐	ahmadmz.online	SOA	ns-132.awsdns-16.com. awsdns-hostmaster.amazon.com. 1 7200 900 1209600 86400				
☐	www.ahmadmz.online	A	dualstack.webapp-lb-1024783460.us-east-1.elb.amazonaws.com.				
☐	_5637602a19018623aab434a09deb1039.www.ahmadmz.online	CNAME	_e050a2a1b0eb0b57a54161dcae80710b.mntkzmvhvg.acm-validations.aws.				
☐	_66c750cf98edfc038c75ae30a918e665.cdn.ahmadmz.online	CNAME	_0fa1a22645de4ab33fa5fa953f31fb1b.bxmgrljqq.acm-validations.aws.				

Step 4: Check the Certificate Status

47. In the **AWS Management Console**, on the **Services** menu, click **Certificate Manager**.

48. Select **List certificate**.

Note: You can see the **Certificate** with **Pending validation**.

Note: **Wait** for **~15 mnts**, before you can see the **Certificate** with **Issued Status**.

Certificates (1)					
☐	Certificate ID	Domain name	Type	Status	In use?
☐	5fc3cf57-ed7c-4a41-a16f-2e28ef023551	cdn.ahmadmz.online	Amazon Issued	Issued	No

Step 5: Configure Domain for Cloud Front Distribution

49. In the **AWS Management Console**, on the **Services** menu, click **Cloud Front**.

50. **Go to left** and select the **Distribution**.

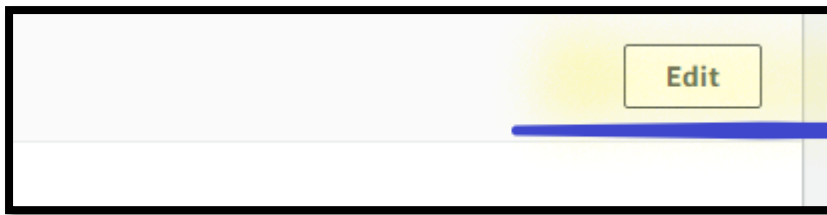
a. Open the **Distribution**.

Distributions (1) Info				
Search all distributions				
☒	ID	Domain name	Origins	Status
☒	E14XVCZHA8FYN	d2drk34j1tjz6k.cloudfront.net	ec2-3-92-107-77.compute-1.amazonaws.com	Enabled

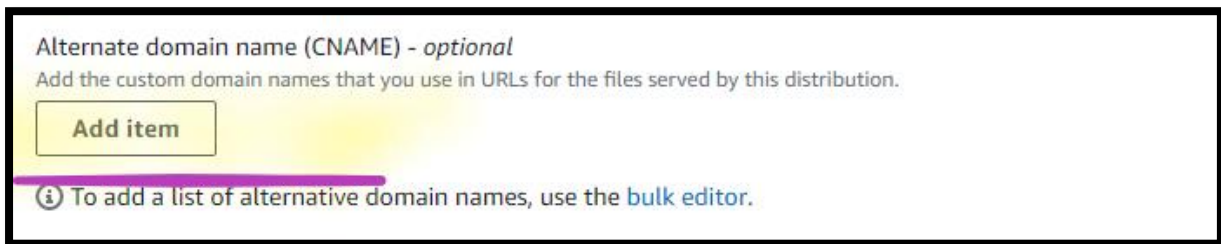
b. Select **General**.

General	Origins	Behaviors	Error pages	Geographic restrictions	Invalidations	Tags
Details						

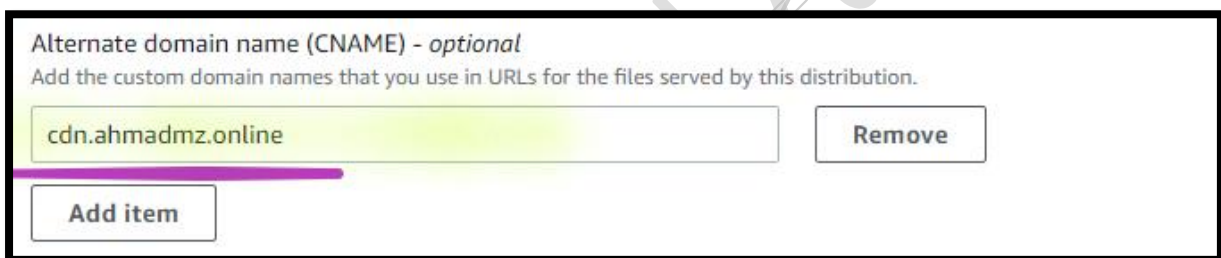
i. Select **Edit**.



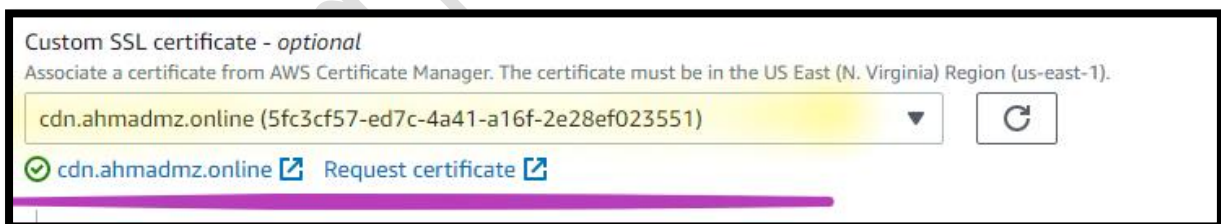
a) **Alternate domain name (CNAME):** Select **Add item**.



1) Write **cdn.YOUR-DOMAIN** (like **cdn.ahmad.com**).



2) **Custom SSL certificate:** Dropdown and select **Certificate**.



3) Select **Save changes**.

Step 5: Create Record for CDN

51. In the **AWS Management Console**, on the **Services** menu, click **Route53**.

52. **Go to the left**, select **Hosted zones**.

a. Open your **Domain name**.

i. Select **Create record**.

- a) **Record name:** Write **cdn**.
- b) **Record type:** Select **A – Routes Traffic to IPv4 address and some AWS resources**.
- c) **Alias:** **Enable** the **Alias**.
- d) **Route traffic to:**
 - 1) **Choose an endpoint:** Dropdown and select **Alias to CloudFront distribution**.
 - 2) **Choose distribution:** Dropdown & select the cloud front **Distribution**.

The screenshot shows the AWS Route 53 console. The 'Record name' field is set to 'cdn' and the 'Record type' is set to 'A – Routes traffic to an IPv4 address and some AWS resources'. The 'Route traffic to' section has the 'Alias' radio button selected. The dropdown menu for 'Route traffic to' shows 'Alias to CloudFront distribution' selected, with 'US East (N. Virginia)' as the region. A search bar at the bottom shows 'd2drk34j1tjz6k.cloudfront.net' as the selected distribution.

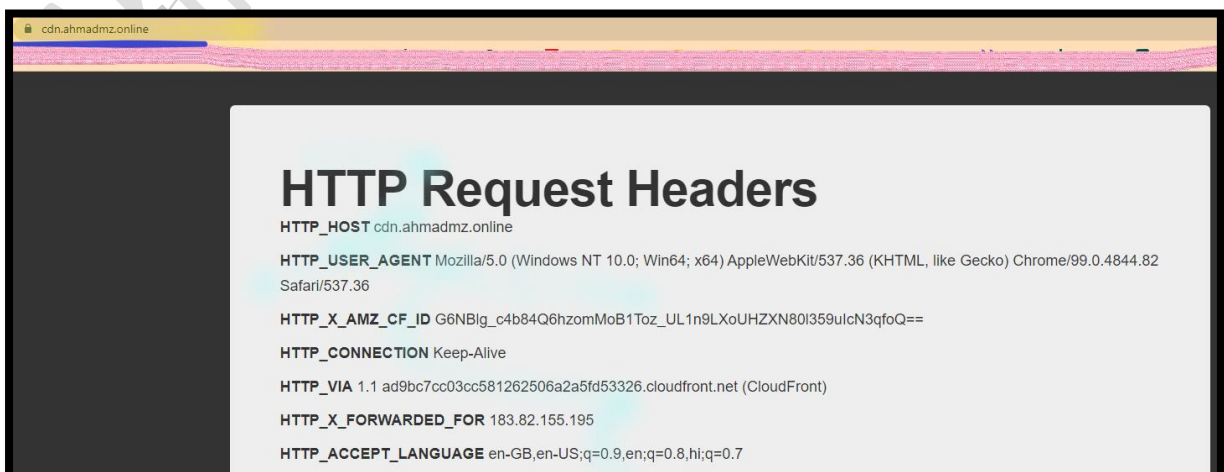
- e) Select **Create records**.

Step 6: Copy the FQDN

53. From, **Domain name Hosted zones**.
 - a. **Copy** the **cdn** record name ((like **cdn.ahmad.com**)).

Step 7: Access the Load Balancer using HTTP

54. From your **local Desktop/Laptop Web browser**, type **FQDN** of **cdn record** (like **https://cdn.ahmad.com**).



Task 8: Delete Environment

Step 1: Delete CloudFormation Stack

55. In the AWS Management Console, on the **Services** menu, Click **CloudFormation**.

56. **Go to the left** navigation pane, Click on **Stack**.

57. Select **lab-waf** stack.

- a. Select **Delete**.
- b. Select **Delete stack**.

Step 2: Delete the WAF

58. In the AWS Management Console, on the **Services** menu, click **WAF & Shield**.

Delete the Web ACLs

59. **Go to the left**, select **Web ACLs**.

- a. Dropdown and Select **Global (CloudFront)**.
- b. Open the **Lab-ACL**.
- c. Select the **Rules**.
 - i. Select the **LabRule** and **LabXSS** and **LabSQL**.
 - ii. Select **Delete**.
 - a) When prompt to confirm delete, type **delete**.
 - b) Select **Delete**.

60. **Go to the left**, select **Web ACLs**.

- a. Dropdown and Select **Global (CloudFront)**.
- b. Open the **Lab-ACL**.
- c. Select the **Associated AWS resources**.
- d. Select **Cloud Front Distribution**.
- e. Select **Disassociate**.

- i. When prompt to confirm disassociation, type **remove**.
 - ii. Select **Disassociate**.
- 61. **Go to the left**, select **Web ACLs**.
 - a. Dropdown and Select **Global (CloudFront)**.
 - b. Select and Open the **Lab-ACL**.
 - i. Select **Delete**.
 - a) When prompt to confirm delete, type **delete**.
 - b) Select **Delete**.

Step 3: Delete the CloudFront

- 62. In the AWS Management Console, on the **Services** menu, Click **CloudFront**.
- 63. **Go to the left** navigation pane, Click on **Distributions**.
- 64. Select your **Cloud Front Distribution**.
 - a. Select **Disable**.
 - b. Select **Disable**.

Note: **Wait**, till **Status** column shows you **Disabled**.

- 65. Select your **Cloud Front Distribution**.
 - a. Select **Delete**.
 - i. When prompt to confirm delete, type **delete**.
 - ii. Select **Close**.

Delete the IP sets

- 66. **Go to the left**, select the **IP sets**.
 - a. Dropdown and Select **Global (CloudFront)**.
 - b. Select the **LabIPMatch**.
 - i. Select **Delete**.

- a) When prompt to confirm delete, type **delete**.
- b) Select **Delete**.

Step 4: Delete the Certificate

67. In the **AWS Management Console**, on the **Services** menu, click **Certificate Manager**.

68. Select **List certificate**.

- a. Select **www Certificate**.
 - i. Select **Delete**.
 - ii. To confirm deletion, type **delete**.
 - iii. Choose **Delete**.